

Network and IoT Security | NIOsec

Summary

CONTENTS

- 1. Introduction 2
- 2. TLS 2
 - 2.1. Specification 2
 - 2.1.1. Record protocol 2
 - 2.1.2. Subprotocols 3
 - 2.1.3. Handshake 3
 - 2.2. Modern TLS Variants 3
 - 2.2.1. DTLS 3
 - 2.2.2. QUIC 3
 - 2.3. Attacks 4
 - 2.3.1. Heartbleed 4
 - 2.3.2. Syn Flooding 4
 - 2.3.3. TCP Reset 4
 - 2.3.4. FREAK 4

1. INTRODUCTION

OSI Stack:

<i>Communication layers</i>	<i>Security protocols</i>
Application layer	Web Application Security, VoIP Security, SW Security
Transport layer	TLS
Network layer	IPsec
Data Link layer	L2TP, IEEE 802.1X, IEEE 802.1AE, IEEE 802.11i (WPA2)
Physical layer	Quantum Key Exchange

The CIA triad is a foundational information-security model stating that systems should protect:

Confidentiality: Keeping information secret

Integrity: Keeping information correct and unaltered

Availability: Ensuring information and systems remain accessible

Additional desired properties include:

Authenticity: Adversary cannot claim to be someone else

Accountability/Non-repudiation: Actions can be traced to actor

2. TLS

SSL and TLS are protocols for internet handshakes and encrypted transmission. Secure Socket Layer (SSL) came first, then after v3.0 it became Transport Layer Security (TLS), currently v1.3. People still use SSL as a term, even though technically it's now TLS.

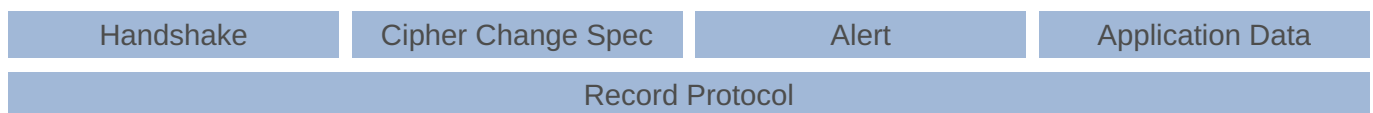
TLS 1.2: Introduced authenticated encryption, which is the most modern form of encryption. It's a more flexible protocol, lots of TLS extensions, the hashing function has been improved.

TLS 1.3: The protocol has been redesigned to make it faster. A lot of the old ciphers have been removed to make it more secure. It only supports authenticated encryption (AEAD).

TODO:

W1 slides 22

2.1. SPECIFICATION



2.1.1. Record protocol

All TLS packets are sent using the record protocol. This header is attached to every single message.

<i>Header</i>			<i>Data</i>
Type (1B)	Version (2B)	Length (2B)	...

Type: which kind of TLS message is sent (20,21,22,23)

Version: which TLS version is used

Length: how long is the payload of the message

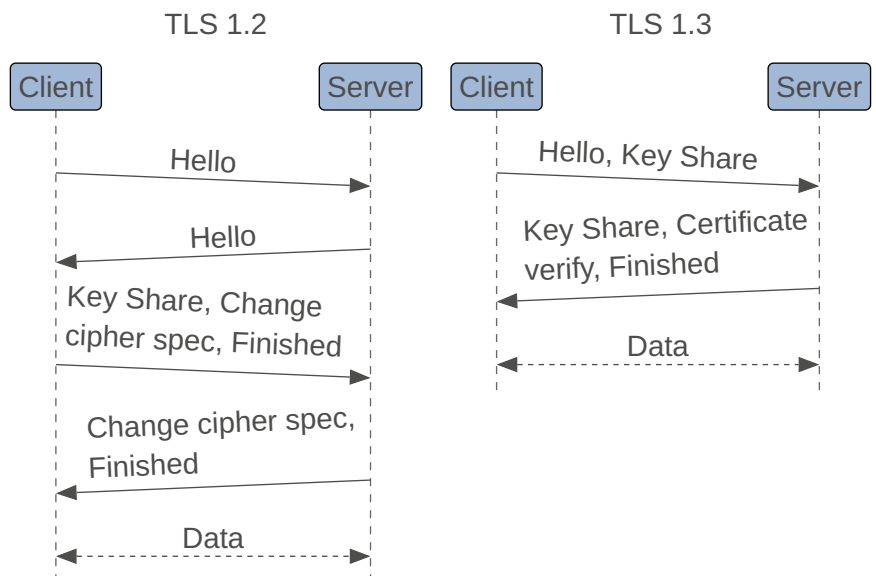
2.1.2. Subprotocols

Protocol	Definition
20 ChangeCipherSpec	The sender has sufficient information and is switching to encryption or to a new cipher suite (sent very rarely). By starting encryption for the first time, it is saying that the handshake has been successful, and encryption can start
21 Alert	An SSL-level alert notification (example close_notify). Not necessarily an error. Example: problem with the handshake, received data length is wrong, warning.
22 Handshake	Messages sent right at the beginning (example ServerKeyExchange). Eg. To establish a cipher, to establish our keys
23 Application Data	Opaque application data. Any applications data once we start the encryption is going to be sent under protocol 23

2.1.3. Handshake

The TLS handshake protocol is used to establish parameters for the remainder of the session. It must:

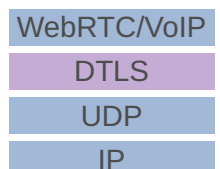
- Agree ciphers and protocols
- Establish shared secrets
- Authenticate server and client
- Be robust to tampering and attacks



2.2. MODERN TLS VARIANTS

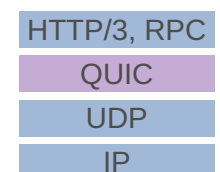
2.2.1. DTLS

- TLS on top of UDP
- Used for WebRTC, VoIP
- Does not provide ordering of packets
- Packets may drop, retransmission is delegated to application



2.2.2. QUIC

- TLS 1.3 + UDP
- Provides reliable communication
 - Stateful
 - Multiple streams
- Used for HTTP/3, RPC



2.3. ATTACKS

2.3.1. Heartbleed

The Heartbeat extension is a keep-alive feature of TLS. The `heartbeat_request` message includes payload length, payload and padding fields. The Heartbleed bug is an implementation flaw in that extension.

- 1) Send message that indicates the maximum payload length (64 KB) that only includes the minimum payload (16 bytes)
- 2) Receive almost 64 KB of random memory that the server returns
- 3) Profit (look for private keys, auth cookies, etc.)

Countermeasures: Update OpenSSL

2.3.2. Syn Flooding

Idea: Fill the TCB (Transmission Control Block) queue storing the half-open (never ACKed) TCP connections so that there will be no space to store TCB for any new half-open connections. Basically the server cannot accept any new SYN packets.

- 1) Use random source IP addresses; otherwise the attacks may be blocked by the firewalls.
- 2) Spam TCP requests
- 3) Profit (sleep well knowing you're a menace to society)

The SYN+ACK packets sent by the server may be dropped because forged IP address may not be assigned to any machine. If it does reach an existing machine, a RST packet will be sent out, and the TCB will be dequeued.

Countermeasures: SYN Cookies

- After a server receives a SYN packet, it calculates a keyed hash (H) from the information in the packet using a secret key that is only known to the server.
- This hash (H) is sent to the client as the initial sequence number from the server. H is called SYN cookie.
- The server will not store the half-open connection in its queue.
- If the client is an attacker, H will not reach the attacker.
- If the client is not an attacker, it sends H+1 in the acknowledgement field.
- The server checks if the number in the acknowledgement field is valid or not by recalculating the cookie.

2.3.3. TCP Reset

Spoof RST Packet to break up a TCP connection between Alice and Bob.

The following fields need to be set correctly: Source IP address, Source Port, Destination IP address, Destination Port, Sequence number (within the receiver's window)

2.3.4. FREAK

- Man-in-the-middle (MitM) downgrades used TLS cipher suite to use export RSA
- MitM then factors 512 bit RSA to get session key

TODO:

https://ciphersuite.info/cs/TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256/